

Defensive Security Assessment Capstone

Sanitized security assessment and remediation report

Scope: Localhost-only training application. No external systems, real credentials, or personal data were used.

Executive Summary

A controlled assessment reviewed configuration, authentication/session handling, input validation, dependencies, and logging. Three material weaknesses and one hardening gap were documented. The remediated implementation was retested with synthetic data.

Findings

ID	Finding	Severity	Remediation
SEC-01	Password exposed in logs	High	Removed password logging
SEC-02	Predictable session ID	High	Random token + safer cookie
SEC-03	Missing input validation	Medium	Length/character/body validation
SEC-04	Missing response hardening	Low	Security headers added

Retest

All defined remediation checks passed. The automated suite verifies password non-disclosure in logs and input validation. Sanitized evidence is stored in evidence/retest_evidence.txt.

Safety

This work is intended for an isolated defensive lab. Do not direct the application or tests at systems you do not own or lack explicit authorization to assess.